AJJIL / MIT REVIEW

Website UAT Evidence, Test Methods and Recommendations

Self-contained technical report | Reporting baseline: 16-18 October 2026 | Compiled: 21 October 2026

Purpose. Provide MIT with actionable findings and demonstrated website checks without requiring access to the private UAT repository. Each included item has a named executed test, a recorded observation, an identified tool or method, and a practical fix or verification recommendation.

EVIDENCE BOUNDARY
This document embeds verbatim or faithfully transcribed case-ledger result excerpts. The original Playwright screenshots and raw browser/network capture files are not available as downloadable bytes in the current report workspace. Therefore no application screenshots are fabricated or claimed embedded. This document is complete without external links, but its raw-evidence strength is limited to the test records shown.

Important: The commands below are safe reproduction instructions reconstructed for MIT. The exact shell command lines originally typed by the test runner were not retained in the accessible records. Recorded results are from historical execution, not a new scan.

5 UAT finding groups with test-record evidence	6 Passing public-site workflows with test records	0 Unchecked Phase 1 requirements counted as passes

Executive findings

Priority	Case ID	Finding (recorded)
High	WEB-DEF-01	HTTP pages return 200 rather than redirecting to HTTPS; sampled HSTS absent.
Medium	WEB-DEF-07	Terms, Privacy and Refund article content matched after normalization.
Medium	WEB-DEF-05 / 06	Contact-type control lacked a label; contrast and link-name violations recorded.
Medium	WEB-R2-01	Mobile menu toggle was not keyboard-focusable.
Medium	WEB-DEF-08	Admin login page emitted front-end addEventListener TypeError.

No conclusion on completed ERP/POS, Master Catalogue end-to-end behavior, penetration testing, load testing, or all 19 mandatory Phase 1 requirements is made in this document.

01 | Website transport configuration

Severity: HIGH | Finding WEB-DEF-01 | Test IDs SEC-01 and WEB-R2-018/019/020 | Reproduced in Rounds 1 and 2

Tool	curl-based transport check (R1); Chrome / Playwright request checks (R2).
Procedure	Send anonymous GET to HTTP and HTTPS for public website and admin login; examine status, redirect URL and Strict-Transport-Security response header.
Recorded R2 result	WEB-R2-018: HTTP 200; remained HTTP; no redirect. WEB-R2-019: HTTP 200; remained HTTP; no redirect. WEB-R2-020: HSTS absent on both sampled HTTPS responses.
Recorded R1 result	SEC-01: Both HTTP origins returned 200, zero redirects; sampled HTTPS lacked HSTS. No credentials sent over HTTP.
Evidence	Test-case result excerpts shown above; raw transport dump recorded locally as restricted/reachability-tls-final.txt (not copied into this PDF).

Reproduction commands for MIT (safe GET requests, no login):

```
curl.exe -sS -D - -o NUL http://ajjil-web.appssquare.com/
curl.exe -sS -D - -o NUL https://ajjil-web.appssquare.com/
curl.exe -sS -D - -o NUL http://back.ajjil.net/login
curl.exe -sS -D - -o NUL https://back.ajjil.net/login
```

Recommendation: Configure the edge/web server to return HTTP 301 or 308 redirecting to equivalent HTTPS URLs. Enable an appropriate Strict-Transport-Security policy on HTTPS after ensuring hosts and dependencies consistently support TLS. Evaluate includeSubDomains/preload separately; avoid applying them until validated.

Acceptance retest: An HTTP GET returns 301/308 with HTTPS Location, then HTTPS returns the expected content and a valid Strict-Transport-Security header. Verify both affected hosts and paths.

> Risk interpretation
> The finding concerns missing enforcement, not absence of HTTPS. The recorded checks did not demonstrate intercepted traffic, stolen credentials or actual exploitation.

02 | Legal policy page content duplication

Severity: MEDIUM | Finding WEB-DEF-07 | Test IDs WEB-08 / WEB-R2-013

Tool	Headed Chrome 154 + Playwright; article-body normalization and SHA-256 comparison.
Procedure	Open Terms, Privacy and Refund pages; exclude page-specific headings/breadcrumbs; normalize paragraph/list article content; compare hashes.
Recorded R1 result	Three routes returned HTTP 200; normalized article bodies yielded identical SHA-256; length 1,649 characters.
Recorded R2 result	All three normalized article bodies shared matching SHA-256 hash, prefix 5d0458eeccb8.
Visual proof	Three original page screenshots are named r2_terms-conditions_article.png, r2_privacy-policy_article.png and r2_refund-policy_article.png. Their PNG bytes were not mounted for this report, so they are not embedded.
Evidence type	Recorded computed hash result plus exact case reference; hash-calculation source script not preserved in this report.

Recommendation: Replace placeholder/shared policy article content with three separate, legally approved policy documents. Review Arabic content, ownership, effective date, and any related links.

Acceptance retest: Confirm each page displays approved topic-specific body text and record separate normalized content hashes and dated screenshots; no duplicate substantive text beyond common terms.

03 | Public form accessibility

Severity: MEDIUM UAT | Findings WEB-DEF-05/06 | Test IDs WEB-09 / WEB-11 / WEB-R2-009

Tool	axe-core v4.14.0 injected into Chrome/Playwright on public home/contact and registration pages.
Recorded contact result	Critical label rule failure at #contact_type_id: accessible name missing.
Recorded R2 result	Serious contrast findings: 2 home nodes and 5 registration nodes; 5 unnamed links.
Recorded R1 result	Homepage: axe 45 passes; contrast serious, label critical, link-name serious, missing h1 moderate and region issues. Registration: axe 42 passes; similar label/link findings.
Evidence	Exact rule counts and target selector in automated assessment records; raw axe JSON local-only.

Recommendation: Associate the contact-type control with a visible label (or equivalent accessible name), give icon-only links accessible names, correct contrast to WCAG AA for relevant text, and verify semantic heading and landmark structure.

Acceptance retest: Re-run axe-core on affected screens plus manual keyboard and screen-reader checks. The rule violations should no longer reproduce.

Scope: axe findings are automated accessibility checks; they do not establish full manual accessibility compliance.

04 | Mobile menu keyboard accessibility

Severity: MEDIUM UAT | Finding WEB-R2-01 | Test ID WEB-R2-004

Tool	Chrome/Playwright at mobile 390x844; semantic DOM inspection and pointer navigation test.
Recorded result	Mobile hamburger toggle is DIV, without accessible role or name, tabIndex=-1; pointer successfully opens it, but the control is not keyboard-focusable.
Corroborating PASS	WEB-R2-003: Pointer click opened mobile navigation and revealed primary links.
Evidence	DOM properties are recorded in the executed test ledger; menu screenshot named r2_mobile_nav_after_click.png. Original DOM notes and image were not mounted in this report.

Recommendation: Implement the hamburger as a semantic button with an Arabic/English accessible label, aria-expanded reflecting state, and keyboard support for Enter/Space, focus order, Escape and menu close.

Acceptance retest: Tab to the menu button, activate by Enter and Space, verify focus/announcement in a screen reader, and confirm pointer behavior remains correct.

05 | Administration-panel runtime error

Severity: MEDIUM UAT | Finding WEB-DEF-08 (JavaScript component) | Test IDs ADM-17 / WEB-R2-015

Tool	Chrome/Playwright browser console monitoring on anonymous HTTPS admin /login.
Recorded R1 result	manifest request returned 403 and front.js:35 raised a null.addEventListener TypeError (2-3 errors on sampled pages).
Recorded R2 result	Login form rendered HTTP 200, while front.js logged TypeError: null.addEventListener. The manifest 403 did not reproduce during R2.
Evidence	Console diagnostic recorded in test results and local raw browser snapshot; original console image/log not embedded here.

Recommendation: Guard DOM listener registration against missing elements, or move binding to a page-specific initialized component. Confirm whether manifest.json is required; if so, fix asset publication/permissions, otherwise remove stale reference.

Acceptance retest: Load login and representative admin pages with console capture, repeat navigation, and confirm no uncaught errors or missing required assets.

Caution: An observed JavaScript error or 403 does not by itself establish a security vulnerability.

06 | Successful, narrowly scoped website checks

These cases are included because the executed test record states PASS and identifies a captured page screenshot. They are not evidence of completed registration, email delivery, checkout or Phase 1 acceptance.

WEB-R2-001 - Homepage desktop render

Tool	Chrome 154 + Playwright, 1365x900
Procedure	GET home; inspect language, direction and render.
Recorded PASS	HTTP 200; AJJIL title, lang=ar, dir=rtl; no console/network errors observed.
Screenshot filename	r2_home_desktop_final.png
Recommendation	Maintain a smoke test at each release.

WEB-R2-002 - Homepage mobile layout

Tool	Chrome 154 + Playwright, 390x844
Procedure	GET home; compare document/body widths to viewport.
Recorded PASS	HTTP 200; widths at most 390px; content and CTA rendered.
Screenshot filename	r2_home_mobile_390x844.png
Recommendation	Regression-test common mobile viewports.

WEB-R2-003 - Mobile menu by pointer

Tool	Chrome 154 + Playwright mobile
Procedure	Click hamburger with pointer; examine menu.
Recorded PASS	Menu opened; primary links and registration entry visible.
Screenshot filename	r2_mobile_nav_after_click.png
Recommendation	Keep pointer behavior while fixing keyboard accessibility.

WEB-R2-005 - FAQ accordion

Tool	Chrome 154 + Playwright
Procedure	Expand FAQ question and inspect aria-expanded.
Recorded PASS	First answer displayed; aria-expanded=true.
Screenshot filename	r2_faq_expanded.png
Recommendation	Retest expansion/collapse with keyboard and assistive tech.

WEB-R2-006 - Registration entry screen

Tool	Chrome 154 + Playwright
Procedure	GET /registration; inspect role choices; no submission.
Recorded PASS	Role-selection options shown; Start disabled until selected.
Screenshot filename	r2_registration_section.png
Recommendation	Test actual registration only with approved disposable account.

WEB-R2-008 - Contact required-field validation

Tool	Chrome 154 + Playwright; requests intercepted
Procedure	Submit empty contact form; inspect required errors.
Recorded PASS	Required errors appeared for email, request type and message; six requests were aborted locally; no message delivered.
Screenshot filename	r2_contact_empty_validation.png
Recommendation	Retest successful delivery with a permitted messaging sink.

Technical proof index and evidence handling

Embedded, readable proof in this PDF: the case identifiers, tested method, recorded actual observations, measured values (status codes, selectors, rule counts and SHA-256 hash prefix), and recommended remediation / retest criteria. No private GitHub access is needed to read any of these.

Evidence group	Source file basename	Original binary/log access
R1 executed UAT cases	WEB_UAT_EXECUTION_RESULTS.csv	Case results available; original restricted raw logs not embedded.
R2 executed UAT cases	WEB_UAT_ROUND2_RESULTS.csv	Case results available; original PNGs not embedded.
Finding classifications	WEB_UAT_ROUND2_DEFECTS.csv	Written disposition accessible; no raw private captures included.
Screenshots & raw capture index	WEB_UAT_EVIDENCE_INDEX.csv	Filename references only; screenshot bytes not mounted.
Accessibility evidence	WEB_UAT_ACCESSIBILITY_REPORT.md	Tool/rule details recorded; raw axe JSON not embedded.
Security and transport evidence	WEB_UAT_SECURITY_REPORT.md	Transport and SID observation recorded; private proof file not embedded.

Explicit exclusions - no sufficient original proof available here

The following were deliberately not promoted into findings in this handoff: Unifonic SID exposure and raw authenticated settings, Master Catalogue seven-category subcategory issue, October 20 cookie attributes/security-header check, historical CORS observation, completed coupon CRUD, later Round 3 finding changes, and ERP/POS, stock or cross-tenant checks. Some are documented elsewhere; the necessary original authenticated screenshots, raw captures or new source files were not supplied for inclusion.

For an image-inclusive final version: supply the original UAT screenshot folders or the 13-page Round 3 evidence PDF plus sanitized raw network headers and browser logs. Reissue this report embedding each original image next to its corresponding case, without external links.

> Security and acceptance boundary
> This is an evidence-led UAT handoff, not a full penetration test, source-code audit, security certification, ERP/POS acceptance or load test. The 19 mandatory Phase 1 requirements remain unverified at the overall acceptance level according to the recorded campaign.